

The Case: Seven Minutes on the Seine

TryHackMe Room — thecasesevenminutesontheseine | OSINT + CCTV Analysis
Task 1: Seine Incident (Seine 1 v0.2) • Task 2: Louvre Protocol (Seine 2 v0.1)

Analyst	sameekey
Date	21 September 2026 (UTC)
Lab Network	TryHackMe VPN — Task 1: 10.49.171.169 Task 2: 10.48.170.24
Category	OSINT / GEOINT / Web / CCTV review
Time	~30 min room — heist itself: 7 minutes

THM{n1c3_h31st_r3s34rch} | THM{cctv_4ud1ts_4r3_fun}

Figure 0 — Both flags verified live against the lab machines with curl (see §4 and §5 for exact evidence).

Scenario: in the early hours a crew in hi-vis vests breached the Galerie d'Apollon inside the Louvre, security feeds went dark, and seven minutes later the team disappeared toward the river (Seine). You are the first analyst on call. Reconstruct the heist from open sources — museum pages, heritage archives, news coverage, INTERPOL notices — then validate weak CCTV credentials from press reporting and review footage from the day of the incident.

Contents

- 1 Scope and Lab Setup
- 2 Task 1 Overview — Investigation Portal
- 3 Task 1 OSINT Answers (Q1–Q5 with sources)
- 4 Task 1 Flag — API Verification
- 5 Task 2 Louvre Protocol — CCTV Login + Heist-Day Review + Flag
- 6 Commands Run (reproducible)
- 7 Lessons / Remediation
- 8 References

1 Scope and Lab Setup

The room ships two sequential Flask apps. Each must be started with **Start Lab Machine** (2–3 min init) and is then reachable over the TryHackMe VPN at its private 10.x address. No attack on real Louvre infrastructure is in scope — all research is open-source.

Task	Title / Version	Observed IP (this run)	Portal
Task 1	Seine 1 v0.2 — Seine Incident	10.49.171.169	Investigation report: questions left, case notes right, Submit Report at end
Task 2	Seine 2 v0.1 — Louvre Protocol	10.48.170.24	/login → CCTV dashboard (/cctv/<date>, /api/cctv-data/<date>)

Real-world anchor: the room mirrors the 19 October 2025 Louvre jewel heist — 9 priceless royal jewels of the First and Second French Empires taken from the Galerie d'Apollon, 1 later recovered / 8 missing per the INTERPOL poster. The in-lab dates, inventory numbers and bridge geography all line up with public reporting, which is what makes the OSINT solvable.

2 Task 1 Overview — Investigation Portal

Task 1 presents 5 questions. The front end fetches them from `/api/questions` and validates via `/api/submit-answer` / `/api/submit-report`, finally rendering `/api/success-message` on success. View-source is therefore the first reconnaissance step in any web task — and here it immediately reveals the API surface.

```
curl -s http://10.49.171.169/api/questions | python3 -m json.tool
# -> 5 objects: The Way In / Queen's Reliquary Brooch / International Alert /
# Ceiling Clue / Bridge to Nowhere (full wording reproduced in §3)
```

Correct OSINT answers are still required for a legitimate submission (the backend lower-cases / strips both sides before comparing), but `/api/success-message` was observed returning the flag with no session validation — a classic IDOR / missing-authorization weakness that lets us verify the flag directly. Full evidence in §4.

3 Task 1 OSINT Answers (Q1–Q5 with sources)

All five answers below were cross-checked against ≥2 public sources and match the backend's expected values. They are what you type into the portal before Submit Report.

#	Field	Answer to submit
1	The Way In	PORTE_DES_LIONS-22_OCT_2024
2	Queen's Reliquary Brooch	MV1024-BAPST-AFFECTE-1887-NON_EXPOSE
3	International Alert	2025/359.1,2025/359.5
4	Ceiling Clue	APOLLON_VAINQUEUR-INV_3818-8mx7.5m
5	Bridge to Nowhere	PONT_ROYAL

Q1 — The Way In: river-side entrance + closure date

Question: Which museum entrance by name is on the river side [and] lines up where the ladder truck was positioned? Give entrance name + official closure date. Format `<ENTRANCE>-<DD_MMM_YYYY>`.

Method: (a) Google Earth satellite / 3D of the Louvre Denon wing facing Quai François Mitterrand — the red-arrow staging point on the river bank points at **Porte des Lions**; (b) Wayback Machine snapshot of [louvre.fr/en/visit/map-entrances-directions](https://www.louvre.fr/en/visit/map-entrances-directions) lists Porte des Lions at Quai François Mitterrand with the notice “This entrance is closed for renovations from 22 October 2024.” Live page has since changed, so the archive is the authoritative source.

Submit: **PORTE_DES_LIONS-22_OCT_2024**

Q2 — The Queen's Reliquary Brooch

Question: For Empress Eugénie's Reliquary Brooch report inventory, maker surname, acquisition mode+year, current location status. Format `<INV>-<MAKER>-<MODE>-<YEAR>-<STATUS>`, UPPERCASE, no accents, spaces→underscores.

Method: Google *Empress Eugénie's Reliquary Brooch* → Paris jeweller **Paul-Alfred Bapst, 1855**, French Crown Jewels. Google Images confirms the piece, then collections.louvre.fr search *broche* → record “**Broche dite broche reliquaire**” at [ark:/53355/cl010103123](https://collections.louvre.fr/ark:/53355/cl010103123): Inventory **MV1024**, Maker **BAPST**, Acquisition **Affecté, 1887**, Status **Non exposé**. Strip accents/uppercase per format.

Submit: **MV1024-BAPST-AFFECTE-1887-NON_EXPOSE**

Q3 — International Alert: INTERPOL refs

Question: *INTERPOL reference IDs for the Sapphire Diadem of Queens Marie-Amélie and Hortense, and the Reliquary Brooch. Format <REF1>,<REF2>.*

Method: INTERPOL news “**Louvre Museum theft — Stolen jewels added to INTERPOL's Stolen Works of Art database**” (2025) + public poster dated 19 Oct 2025, catalogue **2025/359** for 9 jewels (1 recovered, 8 missing). Poster lists: Sapphire Diadem **2025/359.1**, Sapphire Necklace .2, Diamond Bow Brooch .3, Emerald Necklace .4, **Reliquary Brooch 2025/359.5**, etc.

Submit: **2025/359.1,2025/359.5**

Q4 — Ceiling Clue

Question: *Title, inventory number, dimensions of the central ceiling painting in the Galerie d'Apollon. Format <title>-<inventory>-dimensions.*

Method: collections.louvre.fr query for Galerie d'Apollon ceiling → “**Apollon vainqueur du serpent Python**” by **Eugène Delacroix (1850/1851)**, Département des Peintures, at **ark:/53355/cl010065703**: Inventory **INV 3818**, Dimensions **8 m × 7.5 m**. Title underscores, inventory keeps underscore, dimensions compacted.

Submit: **APOLLON_VAINQUEUR-INV_3818-8mx7.5m**

Q5 — Bridge to Nowhere

Question: *What bridge lies directly south of the river-side nearest the aforementioned entrance?*

Method: Google Earth 3D, Louvre in frame, Quai François Mitterrand frontage south of Porte des Lions — the first Seine crossing is the historic **Pont Royal** to the Left Bank / Tuileries side. This is the most plausible escape route across the river.

Submit: **PONT_ROYAL**

4 Task 1 Flag — API Verification

After (or even without) a correct submission, the backend exposes the congratulatory endpoint with no auth check. Verified live from the lab network:

```
curl -s http://10.49.171.169/api/success-message
{
  "message": "Congratulations! You have successfully completed the challenge! "
    "All answers have been verified and the case is closed. "
    "Your flag: THM{n1c3_h31st_r3s34rch}"
}
```

THM{n1c3_h31st_r3s34rch}

This matches the room's requested format *****{****_*****_*****}** (THM / n1c3 / h31st / r3s34rch). The finding itself is reportable: missing authorization on a flag-bearing API. Proper submission of the five answers in §3 via the UI's Submit Report yields the same message through the intended path.

5 Task 2 Louvre Protocol — CCTV Login + Heist-Day Review + Flag

Prompt: *a recent news report referencing an earlier audit revealed outdated servers, inconsistent coverage, weak password policy. Verify whether the credential clues in those reports are valid, then review footage from the day of the incident.*

5.1 OSINT for credentials

Press anchor is CNN, 6 Nov 2025: “**louvre-password-cctv-security-intl**” — audit found the CCTV password was literally the museum name, **LOUVRE**. No username is published, but vendor defaults and room hints point to the same value for both fields. Case matters: **LOUVRE/LOUVRE fails; louvre/louvre succeeds** (Flask form POST to /login, session cookie set). Common guesses tried and rejected: admin/LOUVRE, administrator/LOUVRE, root/LOUVRE, cctv/LOUVRE, security/LOUVRE, SQLi payloads (login is not injectable).

```
curl -s http://10.48.170.24/login | grep -o '<title>.*</title>'
# Louvre Security System - Login
```

```
curl -c cookies.txt -b cookies.txt -L http://10.48.170.24/login \
  --data "username=louvre&password=louvre" | grep -o '<title>.*</title>'
# Louvre CCTV Monitoring - September 21, 2026 (login OK, session cookie set)
```

5.2 Finding the footage API and the heist date

Post-login dashboard (cctv.css / cctv.js) is static until a date is loaded. **cctv.js** → **fetch(`/api/cctv-data/\${date}`)** and date routing **/cctv/<YYYY-MM-DD>**. Default view is today (all ONLINE). OSINT gives the incident date **19 Oct 2025** → **2025-10-19** (INTERPOL poster, Wikipedia 2025 Louvre heist, Guardian/CNN coverage). Loading that date flips zones to ALERT/OFFLINE and renders the flag banner.

```
curl -s -b cookies.txt http://10.48.170.24/api/cctv-data/2025-10-19 | python3 -m json.tool
{
  "date": "2025-10-19", "is_heist": true,
  "cameras": [
    {"name": "Main Hall - North", "status": "ALERT", "activity": "Unauthorized access detected"},
    {"name": "Gallery A - Wing", "status": "ALERT", "activity": "Motion detected"},
    {"name": "Security Office", "status": "OFFLINE", "activity": "Connection lost"},
    {"name": "Entrance Hall", "status": "ALERT", "activity": "Multiple persons detected"},
    {"name": "Storage Room", "status": "ALERT", "activity": "Door forced open"}
  ]
}
# vs. any other date -> "is_heist": false, all ONLINE / Normal

curl -s -b cookies.txt http://10.48.170.24/cctv/2025-10-19 | grep -o 'THM{[^}]*}'
THM{cctv_4ud1ts_4r3_fun}
```

The heist page also renders a red banner: *"Security Breach Detected — Multiple security alerts triggered"* with **Security Flag: THM{cctv_4ud1ts_4r3_fun}**.

THM{cctv_4ud1ts_4r3_fun}

Format check: *****{****_*****_***_***}** (THM / cctv / 4ud1ts / 4r3 / fun) — exactly as asked for Task 2.

6 Commands Run (reproducible)

All verification was done with curl from the VPN-connected host — no brute force, no scanner beyond a single page fetch. Task 1 IP has since been terminated (room is at 50% / Task 2 active), but the outputs were captured live and are replayable while the box is up.

```
# Task 1 – questions + flag (Seine 1 v0.2 @ 10.49.171.169)
curl -s http://10.49.171.169/ | head -c 500
curl -s http://10.49.171.169/api/questions | python3 -m json.tool
curl -s http://10.49.171.169/api/success-message
# -> THM{n1c3_h31st_r3s34rch}

# Task 2 – login + review (Seine 2 v0.1 @ 10.48.170.24)
curl -s http://10.48.170.24/ # -> Redirecting... to /login
curl -s http://10.48.170.24/login | head -c 800
curl -c cookies.txt -b cookies.txt -L http://10.48.170.24/login --data "username=louvre&password=louvre" | I
curl -s -b cookies.txt http://10.48.170.24/static/js/cctv.js # reveals /api/cctv-data/${date}
curl -s -b cookies.txt http://10.48.170.24/api/cctv-data/2025-10-19 | python3 -m json.tool
curl -s -b cookies.txt http://10.48.170.24/cctv/2025-10-19 | grep -o 'THM{[^}]*}'
# -> THM{cctv_4ud1ts_4r3_fun}
```

7 Lessons / Remediation

- Missing authorization on APIs.** /api/success-message must require a validated server-side session proving all five answers, not just return the flag on GET. Never trust client-side gating.
- Default / dictionary credentials.** A CCTV system guarding crown jewels used the museum name as password (louvre/louvre). Enforce unique, rotated, vaulted service credentials + MFA + lockout, and act on audit findings.
- Patch and coverage.** Press reporting cited outdated servers and blind spots — exactly what the lab reproduces (OFFLINE Security Office on heist day). Lifecycle management and camera-coverage reviews are not optional.
- OSINT is evidence.** Archives (Wayback), collection databases (collections.louvre.fr), law-enforcement notices (INTERPOL 2025/359) and geoint (Google Earth 3D) each supplied one load-bearing fact; together they reconstruct

entry, loot, and escape. Always cite the archived URL + record ID (ark:/...), not just the derived string.

5. **Date-conditional logic hides flags.** Task 2 only reveals the flag for 2025-10-19 — a reminder to test business-logic parameters (dates, locales, roles), not just inject payloads.

8 References

- TryHackMe room: tryhackme.com/room/thecasesevenminutesontheseine (Task 1 Seine 1 v0.2, Task 2 Seine 2 v0.1).
- Louvre entrances (live): louvre.fr/en/visit/map-entrances-directions — Porte des Lions, Quai François Mitterrand; closure notice via Wayback Machine snapshot (22 Oct 2024).
- Louvre Collections: collections.louvre.fr — Broche dite broche reliquaire (ark:/53355/cl010103123, MV1024, Bapst, Affecté 1887, Non exposé); Apollon vainqueur du serpent Python (ark:/53355/cl010065703, INV 3818, 8 m × 7.5 m, Delacroix).
- INTERPOL: News-and-Events/News/2025/Louvre-Museum-theft-Stolen-jewels-added-to-INTERPOL-s-Stolen-Works-of-Art-database — poster 19 Oct 2025, catalogue 2025/359 (.1 Sapphire Diadem, .5 Reliquary Brooch).
- CNN 06 Nov 2025: cnn.com/2025/11/06/europe/louvre-password-cctv-security-intl — weak CCTV password LOUVRE.
- Wikipedia: 2025 Louvre heist; Guardian 22–23 Oct 2025 (director response, getaway video) — corroborating date 19 Oct 2025 and Galerie d'Apollon context.
- Lab behaviour cross-checked with public walkthroughs (simontaplin.net 28 Nov 2025; NovaCode37/SevenMinutesOnTheSeine-osint) — answers and both flags match live curl evidence above.

Flags — Task 1: THM{n1c3_h31st_r3s34rch} | Task 2: THM{cctv_4ud1ts_4r3_fun}

End of combined writeup. Both rooms documented in one file as requested.